

简答题（后端方向）

来源：择栖工作室招新题 · part2 · 五、挑战题 作者：容子棋（2026090902028）

Q1 为什么用户密码不能明文存储在数据库中？简述「哈希（Hash）」和「盐值（Salt）」的作用。

A1 明文存储容易泄露，同时违反了对用户个人隐私保护的 legal 要求。

- **Hash（哈希）**：将明文通过单向散列算法（如 `SHA-256`、`bcrypt`）转换为固定长度的不可逆字符串。
- **Salt（盐值）**：为每个用户密码随机生成一段唯一字符串，与密码拼接后再进行哈希。

两者均用于防止密码泄露。

Q2 什么是「统一异常处理」？相比在每个接口里单独写 try-catch，它有什么优势？

A2 使用框架提供的全局拦截机制（e.g. Spring 的 `@ControllerAdvice`、Spring Boot 的 `@RestControllerAdvice`，或 Express 的全局错误中间件），将整个应用中所有未捕获的异常集中到一处进行统一处理和响应封装。

优势：代码更简洁美观，响应格式统一，维护与修改只需专注一处（方便）。

Q3 JWT（JSON Web Token）由哪三部分组成？服务端如何验证 Token 未被篡改？若 Token 过期，接口应如何响应？

A3 三部分：`Header`、`Payload`、`Signature`。

验证：获取 `Header` 和 `Payload` 并用相同的算法生成 `Signature`，再将新 `Signature` 和原 Token 中的 `Signature` 对比，判断是否一致；同时通过判断 `Payload` 里的 `exp`（过期时间）判断是否超时。

过期响应：`401 Unauthorized`。